

Security+ 2.2 · Common Threat Vectors

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 2.2 — Common Threat Vectors**
(17:14) · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Vetores = como o ataque chega: email/SMS/voz, imagem, arquivo, chamada, credencial default nunca trocada, software infectado, USB baiting, malvertising (anúncio malicioso), credential stuffing (reuso de senha vazada), insider, rede remota, IoT/nuvem física.

Highlights que a prova cobra

- Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA
- Malvertising: anúncio malicioso em site legítimo
- Credential stuffing = USAR senha vazada em outros sites (vs brute force)

Dicas de prova & Cenários Típicos

- 'reuses leaked credentials across multiple sites' = credential stuffing
- 'malicious advertisement on a legitimate website' = malvertising

Cenário clássico de exame: Cenário típico: 'atacante usou senhas vazadas de um data breach em outras contas dos mesmos usuários' = credential stuffing.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 2.2 — Common Threat Vectors)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **MFA:** Multi-Factor Authentication: Autenticação multifator exigindo dois ou mais fatores distintos das categorias: algo que você sabe, algo que você tem, algo que você é, algo que você faz ou algum lugar onde você está.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. No 'acesso inicial' de um ransomware moderno, qual é a falha MAIS explorada?

- A) Firewall mal configurado
- B) Phishing + VPN sem MFA / credencial vazada
- C) Cabo de rede exposto
- D) Falta de antivírus

2. Atacante testa senhas VAZADAS de um site em VÁRIOS outros sites (reúso de senha):

- A) Credential stuffing
- B) Força bruta pura
- C) Rainbow table
- D) Vishing

3. Comprometer um fornecedor de software pra atingir todos os clientes dele (ex: SolarWinds):

- A)** Ataque de cadeia de suprimentos
- B)** Watering hole
- C)** Insider
- D)** Zero-day

4. Cenário corporativo (Common Threat Vectors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Common Threat Vectors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Malvertising: anúncio malicioso em site legítimo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Malvertising: anúncio malicioso em site legítimo...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Common Threat Vectors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Credential stuffing = USAR senha vazada em outros sites (vs brute force)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Credential stuffing = USAR senha vazada em outros sites (vs brute force)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Common Threat Vectors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'reuses leaked credentials across multiple sites' = credential stuffing'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'reuses leaked credentials across multiple sites' = credential stuffing...

8. Cenário corporativo (Common Threat Vectors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'malicious advertisement on a legitimate website' = malvertising'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'malicious advertisement on a legitimate website' = malvertising...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Common Threat Vectors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Cenário típico: 'atacante usou senhas vazadas de um data breach em outras contas dos mesmos usuários' = credential stuffing.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Cenário típico: 'atacante usou senhas vazadas de um data breach em outras c...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Common Threat Vectors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — Phishing + VPN sem MFA / credencial vazada.

✓ **Por que está certa:** A alternativa correta é: Phishing + VPN sem MFA / credencial vazada. No domínio de Ameaças, Vulnerabilidades e Mitigações da CompTIA Security+ SY0-701, o ransomware moderno (como operações de Ransomware-as-a-Service) utiliza táticas de acesso inicial que exploram o fator humano e configurações inadequadas de autenticação. O phishing continua sendo o vetor mais prevalente: e-mails maliciosos, mensagens em redes sociais ou sites falsos induzem o usuário a entregar credenciais ou executar cargas maliciosas. Além disso, VPNs sem MFA (autenticação multifator) permitem que credenciais vazadas em vazamentos de dados ou compradas em mercados clandestinos sejam usadas diretamente para acesso remoto à rede corporativa. A combinação de phishing para obter credenciais e a ausência de MFA em VPNs é uma das falhas mais exploradas, pois contorna perímetros tradicionais e dá ao atacante acesso legítimo à rede. A CompTIA enfatiza que a implementação de MFA é uma mitigação crítica contra esse vetor.

✗ **Por que as outras estão erradas:**

- *Firewall mal configurado:* Um firewall mal configurado pode permitir tráfego não autorizado, mas não é o vetor de acesso inicial mais explorado em ransomware moderno. Firewalls tradicionais atuam na camada de rede e, quando bem configurados, bloqueiam portas e serviços expostos. No entanto, ataques modernos frequentemente usam credenciais válidas obtidas por phishing ou vazamento, o que faz com que o tráfego pareça legítimo e não seja bloqueado por regras de firewall. Além disso, a exploração de firewall geralmente requer vulnerabilidades específicas ou erros graves de configuração, menos comuns do que o comprometimento de credenciais. Portanto, não é a falha mais explorada.
- *Cabo de rede exposto:* Um cabo de rede exposto é uma vulnerabilidade física que permite a um atacante com acesso local conectar-se à rede. Embora seja um risco em ambientes com controle de acesso físico deficiente, não é um vetor típico de acesso inicial para ransomware moderno, que geralmente é executado remotamente por meio de phishing, exploração de serviços expostos ou credenciais comprometidas. Ataques físicos exigem proximidade e podem ser mitigados com segurança física, mas não representam a principal porta de entrada para campanhas de ransomware em larga escala.
- *Falta de antivírus:* A ausência de antivírus é uma deficiência de controle, mas não é o vetor de acesso inicial mais explorado. Antivírus modernos são eficazes contra malware conhecido, mas ransomware sofisticado frequentemente usa técnicas de evasão (ofuscação, fileless, living-off-the-land) que podem contornar soluções baseadas em assinaturas. Além disso, o acesso inicial ocorre antes da execução do ransomware, por meio de credenciais comprometidas ou phishing. A falta de antivírus agrava o impacto, mas não é a falha primária que permite a entrada do atacante. A CompTIA destaca que a conscientização e o MFA são mais críticos para prevenir o acesso inicial.

2) A — Credential stuffing.

✓ **Por que está certa:** Credential stuffing é um ataque cibernético no qual o atacante utiliza listas de credenciais (pares de usuário e senha) obtidas de violações de dados em um site para tentar autenticar em vários outros sites, explorando a prática comum de reuso de senhas. O ataque é automatizado e depende de grandes volumes de credenciais vazadas. Diferencia-se da força bruta pura porque não tenta adivinhar senhas, mas usa combinações já conhecidas. É um tópico do domínio de Ameaças, Vulnerabilidades e Mitigação da Security+ (SY0-701), objetivo 2.4, que aborda técnicas de ataque.

✗ **Por que as outras estão erradas:**

- **Força bruta pura:** Força bruta pura é um método de ataque que tenta exaustivamente todas as combinações possíveis de caracteres até encontrar a senha correta. No credential stuffing, o atacante não testa combinações aleatórias; ele usa credenciais previamente vazadas e válidas em outro contexto. A força bruta é computacionalmente intensiva e facilmente detectável por bloqueios de conta, enquanto o credential stuffing explora a reutilização de senhas e pode ser mais furtivo, pois as credenciais são legítimas. Portanto, a força bruta pura não descreve o cenário de teste de senhas vazadas em vários sites.
- **Rainbow table:** Rainbow table é uma técnica de quebra de hash que utiliza tabelas pré-computadas de hashes de senhas para reverter funções de hash criptográficas. Ela é usada quando o atacante obtém hashes de senhas e deseja descobrir as senhas em texto claro. No entanto, o enunciado descreve o uso de senhas já vazadas (em texto claro ou já quebradas) para autenticar em outros sites, não a quebra de hashes. Rainbow tables não se aplicam diretamente ao credential stuffing, que não requer quebra de criptografia, mas sim a exploração de reúso de credenciais.
- **Vishing:** Vishing é uma forma de engenharia social que utiliza chamadas telefônicas ou mensagens de voz para enganar vítimas e obter informações confidenciais, como senhas ou dados financeiros. Não envolve o teste automatizado de credenciais vazadas em múltiplos sites. O cenário descrito é claramente um ataque técnico de automação, não uma interação humana de persuasão. Portanto, vishing não se aplica ao contexto de credential stuffing, que é um ataque em massa baseado em listas de credenciais.

3) A — Ataque de cadeia de suprimentos.

✓ **Por que está certa:** Ataque de cadeia de suprimentos (supply chain attack) ocorre quando um adversário compromete um fornecedor, parceiro ou componente de software/hardware para atingir os clientes finais desse fornecedor. No caso SolarWinds (2020), atacantes comprometeram o processo de build do software Orion, inserindo código malicioso que foi distribuído como atualização legítima a milhares de clientes, incluindo agências governamentais. Esse é o exemplo clássico de ataque à cadeia de suprimentos, conforme descrito no objetivo SY0-701 2.2 (ameaças à cadeia de suprimentos) e 2.3 (vetores de ataque). A questão descreve exatamente esse cenário: comprometer um fornecedor de software para atingir todos os clientes dele.

✗ Por que as outras estão erradas:

- **Watering hole:** Watering hole é um ataque em que o adversário compromete um site legítimo frequentado por um grupo específico de vítimas (ex.: site de um setor industrial) e insere código malicioso para infectar os visitantes. O objetivo é atingir usuários que visitam aquele site, não comprometer um fornecedor de software para distribuir malware a todos os seus clientes. No watering hole, o vetor é o site de terceiros visitado pelas vítimas; na cadeia de suprimentos, o vetor é o próprio produto ou atualização do fornecedor. A questão fala em comprometer um fornecedor de software para atingir todos os clientes dele, o que é supply chain, não watering hole.
- **Insider:** Ameaça interna (insider threat) refere-se a um indivíduo com acesso autorizado (funcionário, contratado, parceiro) que usa esse acesso para causar dano, roubar dados ou facilitar ataques. O atacante é interno à organização, não um fornecedor externo comprometido. No caso SolarWinds, os atacantes eram externos (APT29) que comprometeram a cadeia de suprimentos da SolarWinds; não se trata de um insider da SolarWinds ou dos clientes. Portanto, insider não descreve o cenário de comprometer um fornecedor para atingir seus clientes.
- **Zero-day:** Zero-day refere-se a uma vulnerabilidade desconhecida pelo fornecedor, para a qual não há patch disponível. O ataque explora essa falha antes que seja corrigida. Embora ataques à cadeia de suprimentos possam envolver zero-days, o conceito de zero-day é sobre a natureza da vulnerabilidade, não sobre o vetor de comprometer um fornecedor para atingir clientes. No caso SolarWinds, o ataque não dependeu exclusivamente de uma zero-day; envolveu comprometimento do processo de build e distribuição de atualização maliciosa. A questão pede o

nome do ataque que compromete um fornecedor para atingir todos os clientes, que é supply chain, não zero-day.

4) B — Implementar a solução correspondente: Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Common Threat Vectors): Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) C — Implementar a solução correspondente: Malvertising: anúncio malicioso em site legítimo....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Common Threat Vectors): Malvertising: anúncio malicioso em site legítimo.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) A — Implementar a solução correspondente: Credential stuffing = USAR senha vazada em outros sites (vs brute force)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Common Threat Vectors): Credential stuffing = USAR senha vazada em outros sites (vs brute force).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) D — Implementar a solução correspondente: 'reuses leaked credentials across multiple sites' = credential stuffing....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Common Threat Vectors): 'reuses leaked credentials across multiple sites' = credential stuffing.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: 'malicious advertisement on a legitimate website' = malvertising....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Common Threat Vectors): 'malicious advertisement on a legitimate website' = malvertising.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) B — Implementar a solução correspondente: Cenário típico: 'atacante usou senhas vazadas de um data breach em outras c....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Common Threat Vectors): Cenário típico: 'atacante usou senhas vazadas de um data breach em outras contas dos mesmos usuários' = credential stuffing..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA....

✅ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Common Threat Vectors): Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA.

❌ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.